Государственный университет Молдовы

Факультет Математики и Информатики

Прикладная информатика

Отчет

Лабораторная работа 5 по курсу “Кибербезопасность”

Тема: ” Инструменты сканирования уязвимостей OWASP-ZAP ”

Выполнил студент группы IA2503:

Duleva Anastasia

Проверил преподаватель:

D. Borș

Кишинев 2025

Цель работы:

1. Используйте инструменты OWASP для сканирования уязвимостей в веб-приложениях (2-3

веб-приложения).

2. Определите, какие уязвимости встречаются, и опишите их.

3. Каковы методы решения тех проблем, которые вызваны определенными уязвимостями?

4. Определите другие приложения для сканирования уязвимостей для веб-приложений.

1. Теоретические понятия

OWASP (*Open Web Application Security Project*) - это проект безопасности открытого вебприложения. Сообщество OWASP включает корпорации, учебные заведения и частных лиц по всему миру. Сообщество работает над созданием статей, учебных пособий, документации, инструментов и технологий, которые находятся в свободном доступе. Фонд OWASP - это благотворительная организация 501 (c) (3), которая поддерживает и осуществляет управление проектами и инфраструктурой OWASP. Кроме того, Фонд был зарегистрирован как некоммерческая организация в Европе с июня 2011 года.

Члены сообщества OWASP создают приложения безопасности с учетом человеческого фактора и технологического уровня. Наиболее популярные документы, опубликованные OWASP, включают в себя: Руководство OWASP, см. Руководство OWASP для кода, а также широко используется OWASP Top 10 Project.

Наиболее распространенными инструментами являются среда обучения OWASP, анализатор **WebScarab Proxy** и инструменты **NET**. OWASP состоит из примерно 190 местных глав, которые расположены по всему миру, и тысяч участников в списках обсуждений проекта.

OWASP создает стандарты, первый из которых был опубликован под названием «Стандарт проверки безопасности приложений OWASP (ASVS)». Основная цель OWASP ASVS - стандартизировать диапазон покрытия и уровень строгости, доступные на рынке приложений, обеспечивая безопасность. Целью OWASP ASVS является предоставление набора открытых коммерчески успешных стандартов,

адаптированных к конкретным веб-технологиям. Сборник для веб-приложения уже опубликован. Коллекция веб-сервисов находится в процессе разработки.

Проекты

OWASP - это набор связанных задач с конкретным планом развития и командой разработчиков.

Руководители проекта OWASP отвечают за определение имиджа, схемы и целей проекта, так как они участвуют в продвижении проекта и формировании команды. В настоящее время существует более 130 активных проектов OWASP, а также число проектов, растущих еженедельно. Проект является одним из самых популярных подразделений OWASP, поскольку он дает активистам возможность свободно тестировать различные теории и идеи с профессиональным сообществом поддержки OWASP. Все, что создано OWASP: инструменты, документация и библиотеки кода, распределены по следующим категориям:

• Безопасность - существуют инструменты и документация, которые можно использовать для обеспечения защиты от атак и использования системных недостатков;

• Обнаружение - это инструменты и документация, которые можно использовать для обнаружения системных атак и недостатков;

• Цикл - это инструменты и документация, которые можно использовать для добавления вещей, связанных с безопасностью, в жизненный цикл Программного обеспечения.

Проекты OWASP:

• OWASP Application Security Verification Standard (ASVS);

• OWASP Mantra Security Framework;

• Руководство по тестированию OWASP;

• OWASP Топ-10;

• Полная модель программного обеспечения OWASP.

OWASP ZAP (***Zed Attack Proxy***) - это веб-приложение с открытым исходным кодом для сканирования безопасности. Он предназначен для использования как новичками, специалистами по безопасности приложений, так и профессиональными тестерами на проникновение.

Это один из самых активных проектов OWASP, получивший статус Flagship. Он также полностью интернационализирован и переведен на более чем 25 языков.

При использовании в качестве прокси-сервера он позволяет пользователю манипулировать всем трафиком, проходящим через него, включая трафик с использованием https. Он также может быть запущен в режиме (daemon) «демон», который затем управляется через интерфейс программирования приложения REST.

Этот кроссплатформенный инструмент написан на Java и доступен во всех популярных операционных системах, включая Microsoft Windows, Linux и Mac OS X. ZAP был добавлен в технологический радар ThoughtWorks в мае 2015 года в Trial Circle.

Некоторые из сборок включают в себя:

• Перехват прокси-сервера;

• Традиционный и веб AJAX crawler;

• автоматический сканер;

• пассивный сканер;

• принудительная навигация;

• Fuzzer;

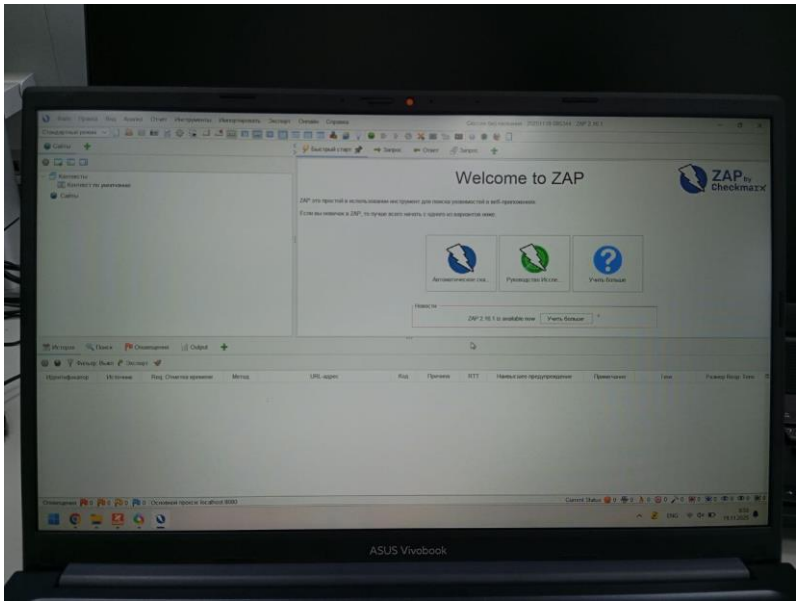
• поддержка WebSocket;

• скриптовые языки;

• Plug-н-Hack. Он имеет архитектуру плагинов и онлайн-магазин, который позволяет добавлять новые функции или обновленные функции.

2. Сканирование уязвимостей

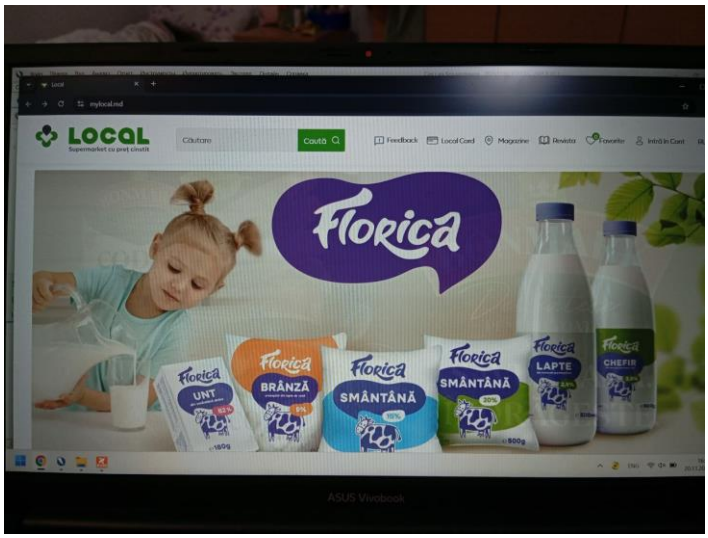
Для сканирования новой веб-страницы, использую приложение OWASP ZAP.

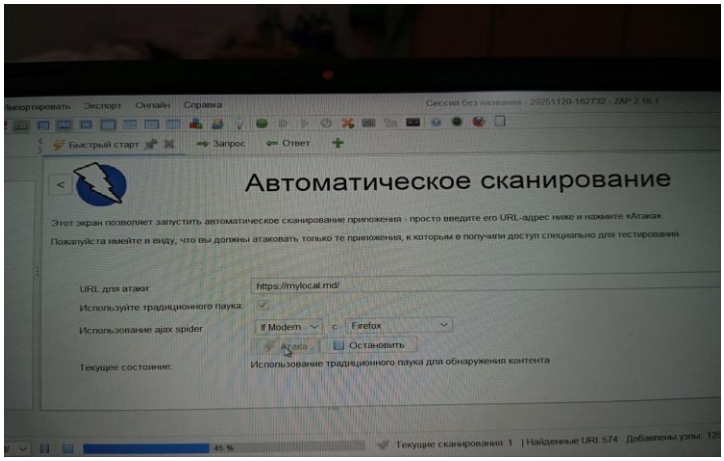


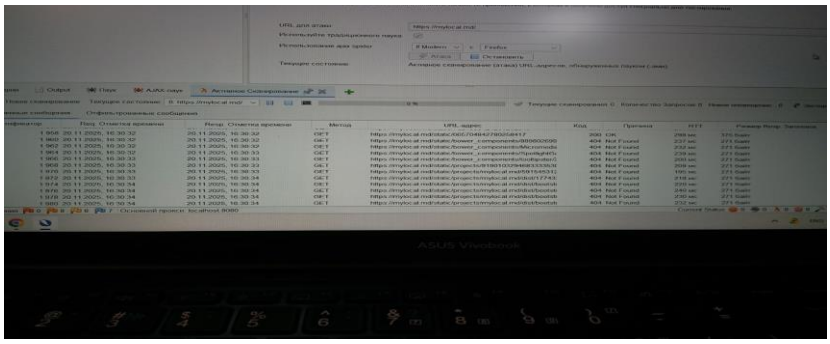
Когда я запускаю приложение OWASP-ZAP, я перехожу во вкладку «Быстрый поиск». В поле «URL-адрес для атаки» я ввожу адрес той веб-страницы, которую хочу просканировать на уязвимости, и нажимаю кнопку «Attack».

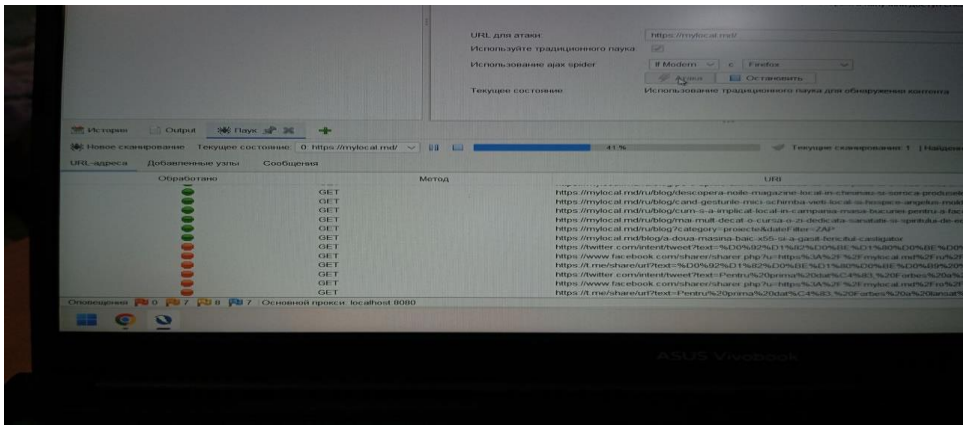
Для сканирования я выбрала сайт telegram, local и сайт с фильмами.

Local



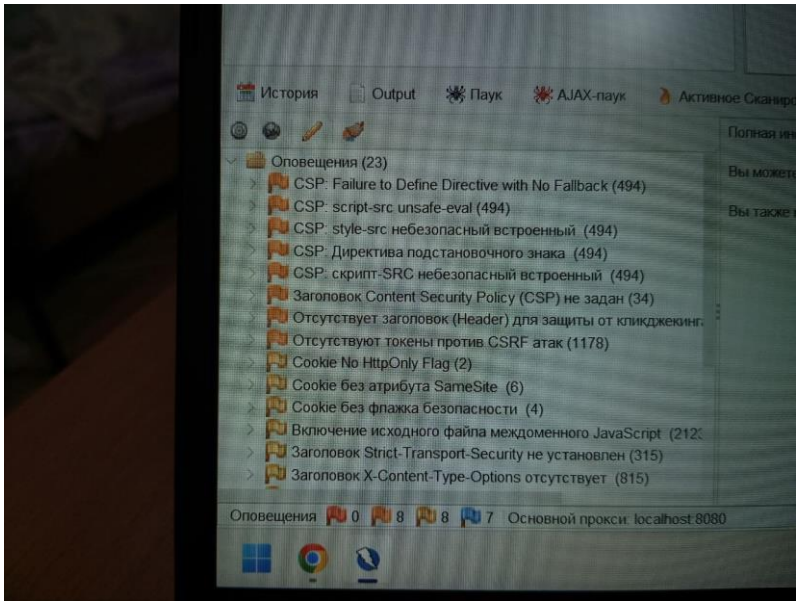


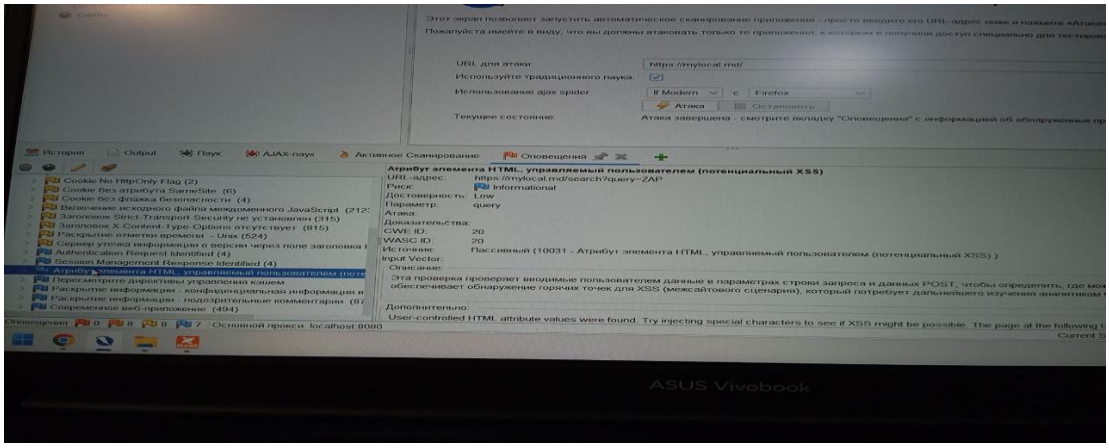


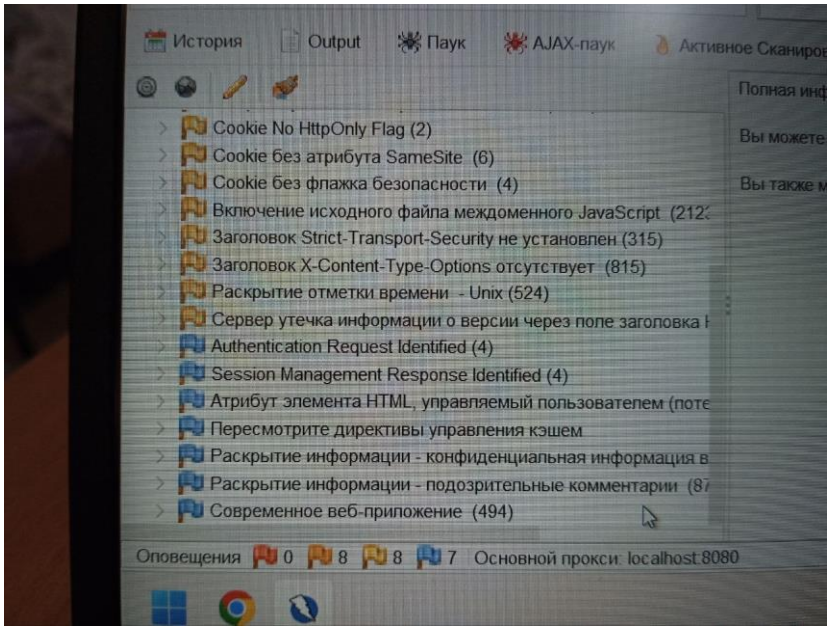


Во время сканирования веб-страницы я вижу, как определяются все типы HTTP-запросов и передаваемые параметры. Когда OWASP ZAP завершает

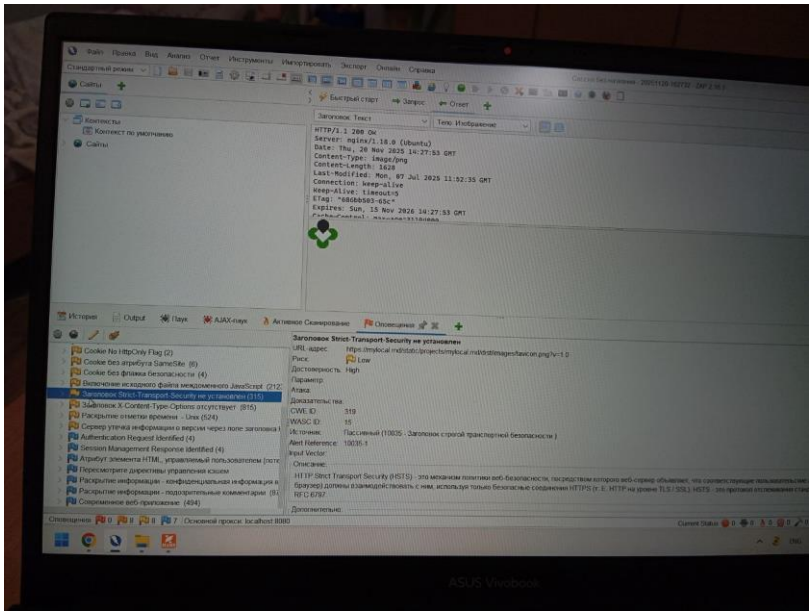
сканирование, результаты отображаются у меня на вкладке «Оповещение».

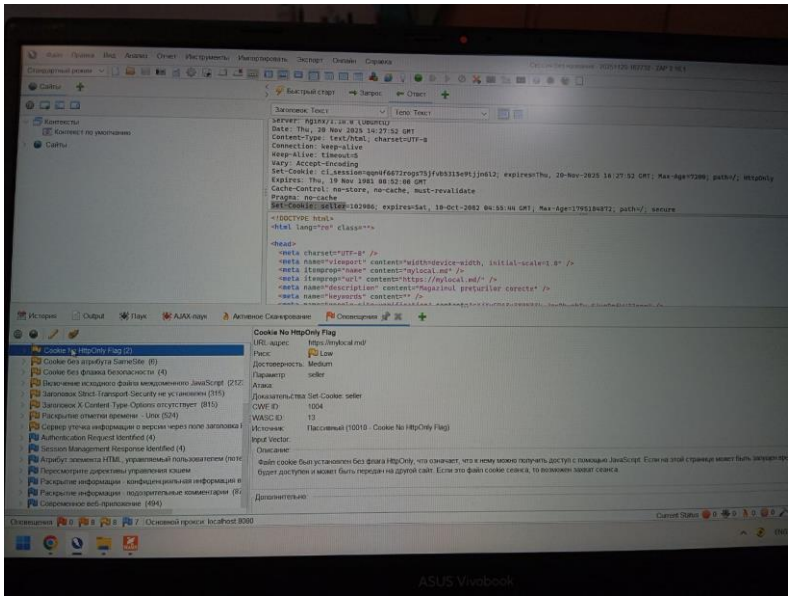






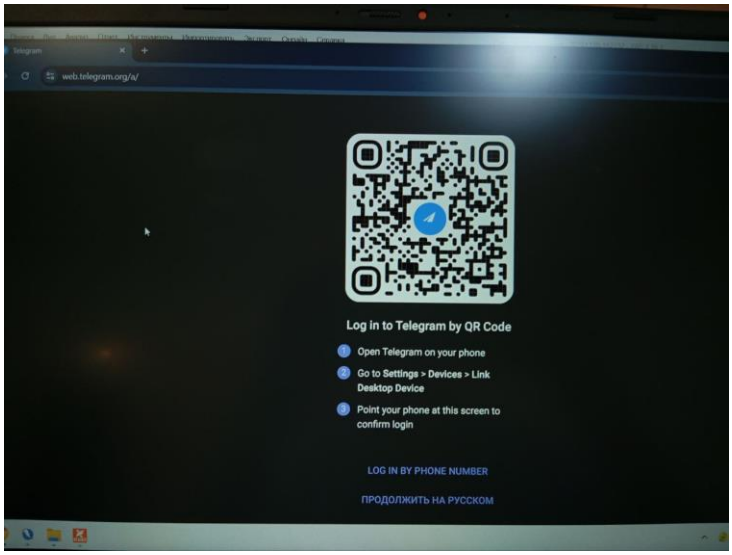
После просмотра результатов сканирования я могу открыть все найденные оповещения, которые сгруппированы по категориям: SQL-инъекция, раскрытие частного IP-адреса, Web Browser XSS Protection Not Enabled, отсутствие заголовка X-Content-Type-Options и другие. Когда я выбираю одно из этих предупреждений, справа отображаются все данные об этой уязвимости.

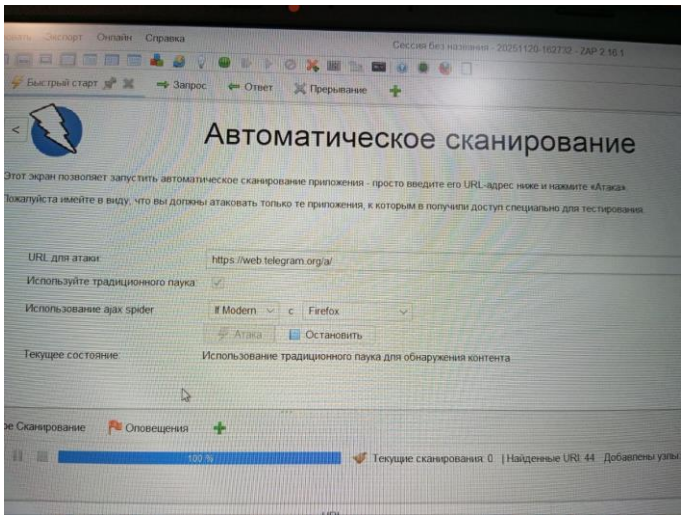


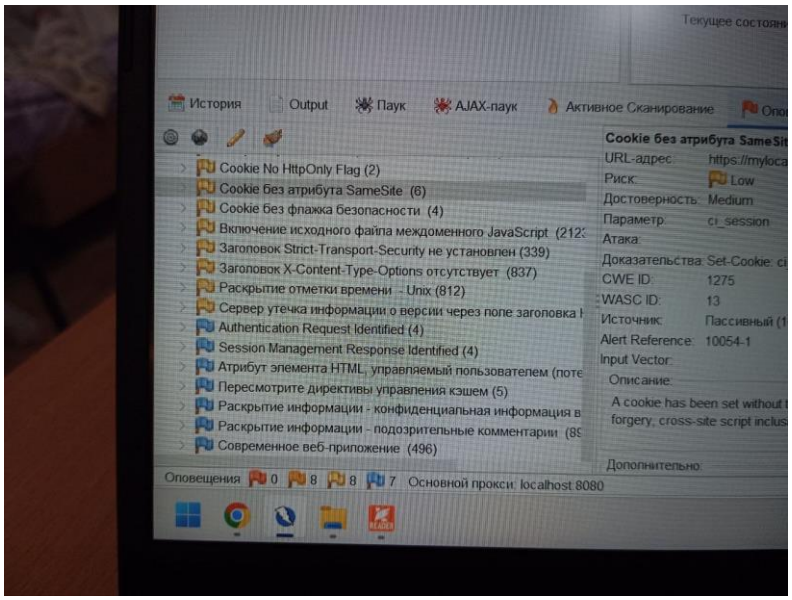


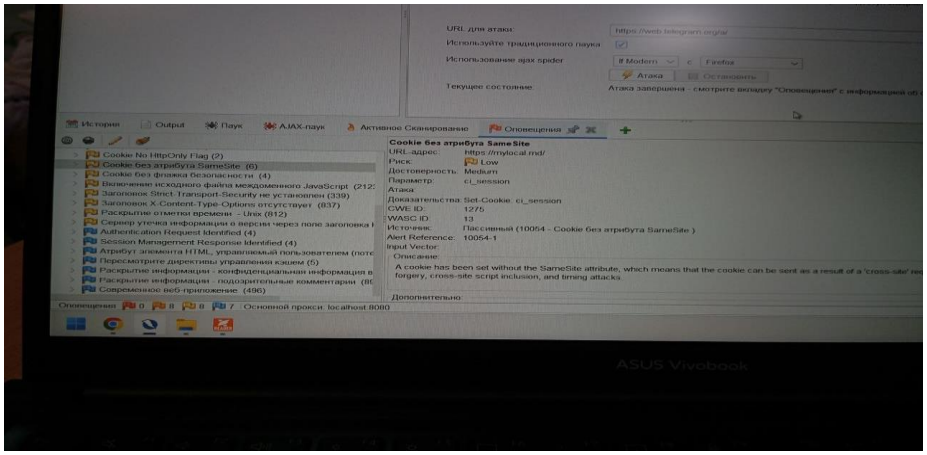
Такую же операцию провожу с сайтом telegram и сайтом фильмов rezka.

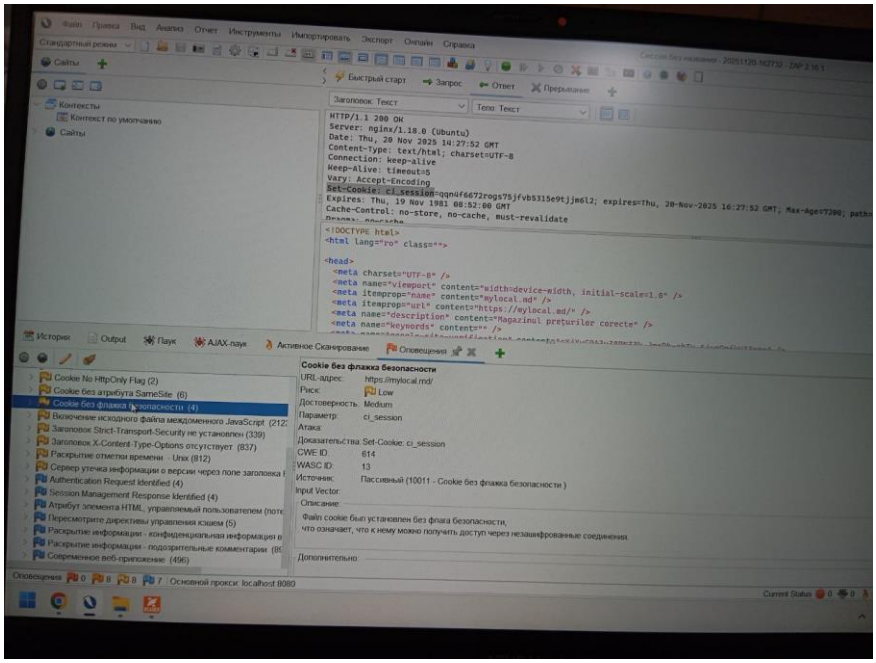
Telegram

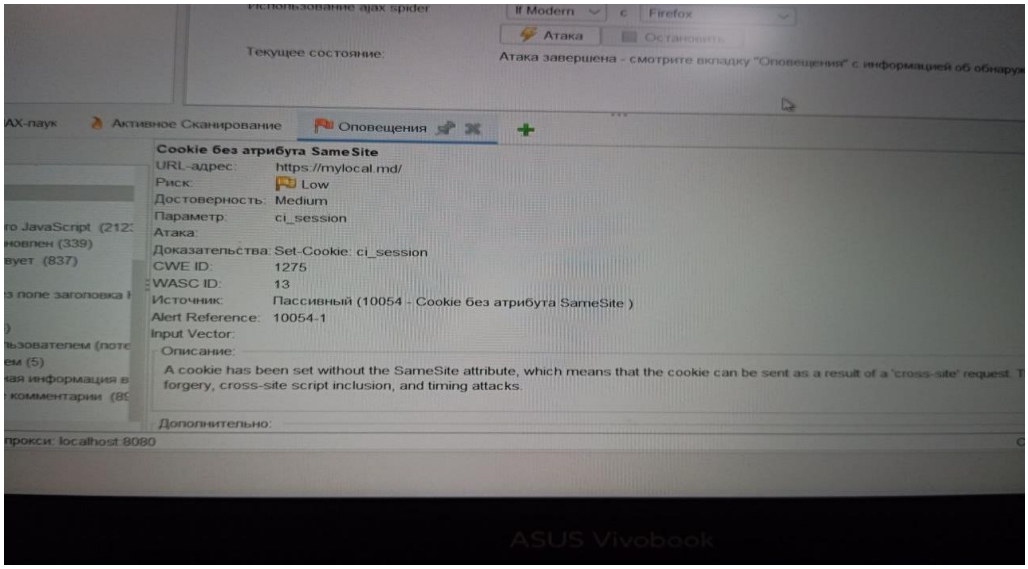

web.telegram.org/a/
Log in to Telegram by QR Code
Open Telegram on your phone
Go to Settings > Devices > Link Desktop Device
Point your phone at this screen to confirm login
LOG IN BY PHONE NUMBER
ПРОДОЛЖИТЬ НА РУССКОМ

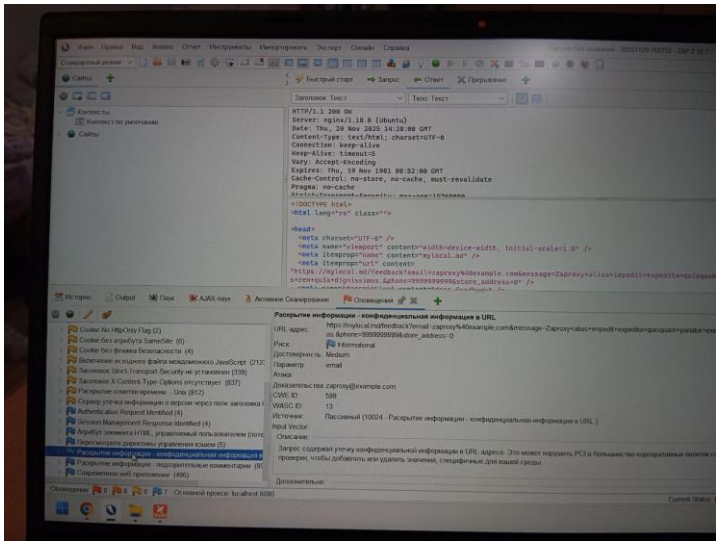

Автоматическое сканирование
Этот экран позволяет запустить автоматическое сканирование приложения - просто введите его URL-адрес ниже и нажмите «Атака».
Пожалуйста имейте в виду, что вы должны атаковать только те приложения, к которым в получили доступ специально для тестирования.
URL для атаки:
https://web.telegram.org/a/
Используйте традиционного паука:
Использование ajax spider
Modern
с
Firefox
Атака
Остановить
Текущее состояние:
Использование традиционного паука для обнаружения контента
Оповещения
Текущие сканирования: 0 | Найденные URI: 44 Добавлены узлы:

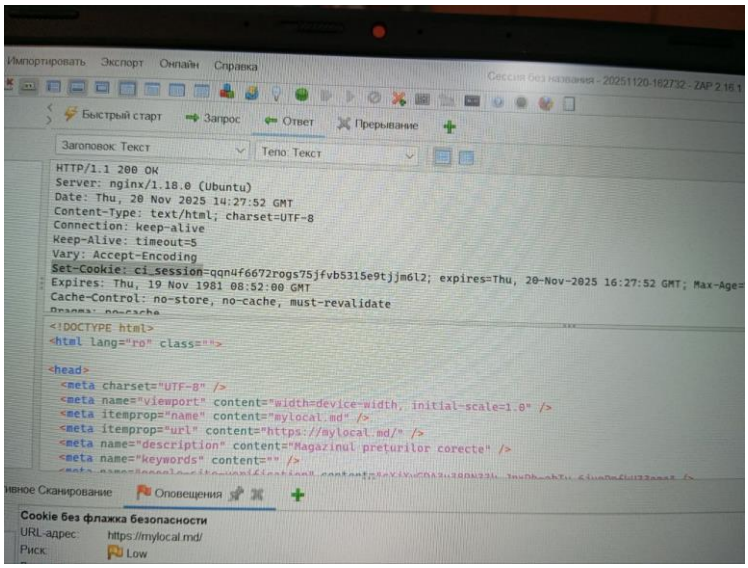

История
Output
Паук
AJAX-паук
Активное Сканирование
Cookie No HttpOnly Flag (2)
Cookie без атрибута SameSite (6)
Cookie без флажка безопасности (4)
Включение исходного файла междоменного JavaScript
Заголовок Strict-Transport-Security не установлен (339)
Заголовок X-Content-Type-Options отсутствует (837)
Раскрытие отметки времени - Unix (812)
Authentication Request Identified (4)
Session Management Response Identified (4)
Пересмотрите директивы управления кэшем (5)
Современное веб-приложение (496)
URL-адрес:
Риск:
Low
Достоверность:
Medium
Параметр:
ci_session
Атака:
CWE ID:
1275
WASC ID:
13
Alert Reference:
10054-1
Input Vector:
Описание:
Дополнительно:
Оповещения 0 8 8 7 Основной прокси: localhost 8080


Cookie Без атрибута SameSite
Cookie No HttpOnly Flag (2)
Cookie без атрибута SameSite (6)
Cookie без флажка безопасности (4)
Заголовок Strict-Transport-Security не установлен (339)
Заголовок X-Content-Type-Options отсутствует (837)
Authentication Request Identified (4)
Session Management Response Identified (4)
Современное веб-приложение (496)

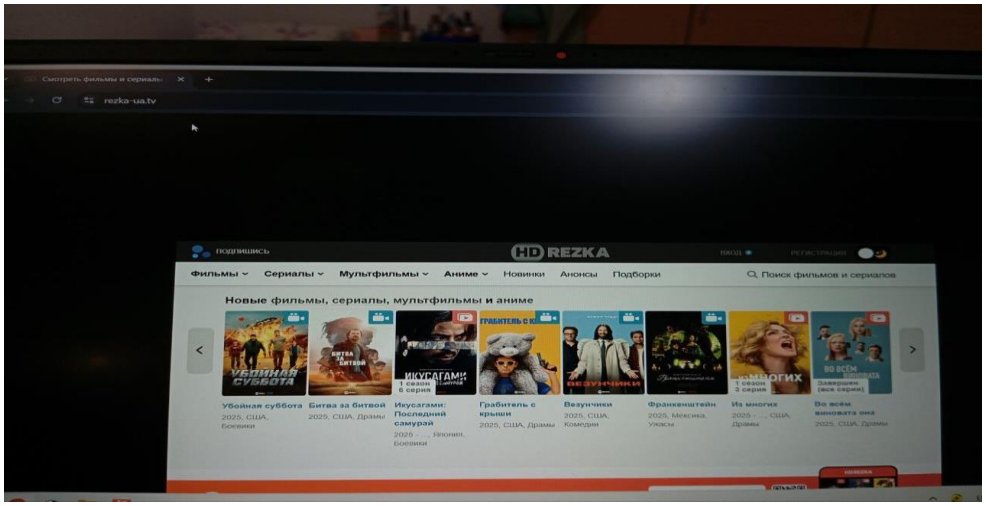

Cookie без флажка безопасности
Cookie No HttpOnly Flag (2)
Cookie без атрибута SameSite (6)
Cookie без флажка безопасности (4)
Заголовок Strict-Transport-Security не установлен (339)
Заголовок X-Content-Type-Options отсутствует (837)
Authentication Request Identified (4)
Session Management Response Identified (4)
Современное веб-приложение (496)

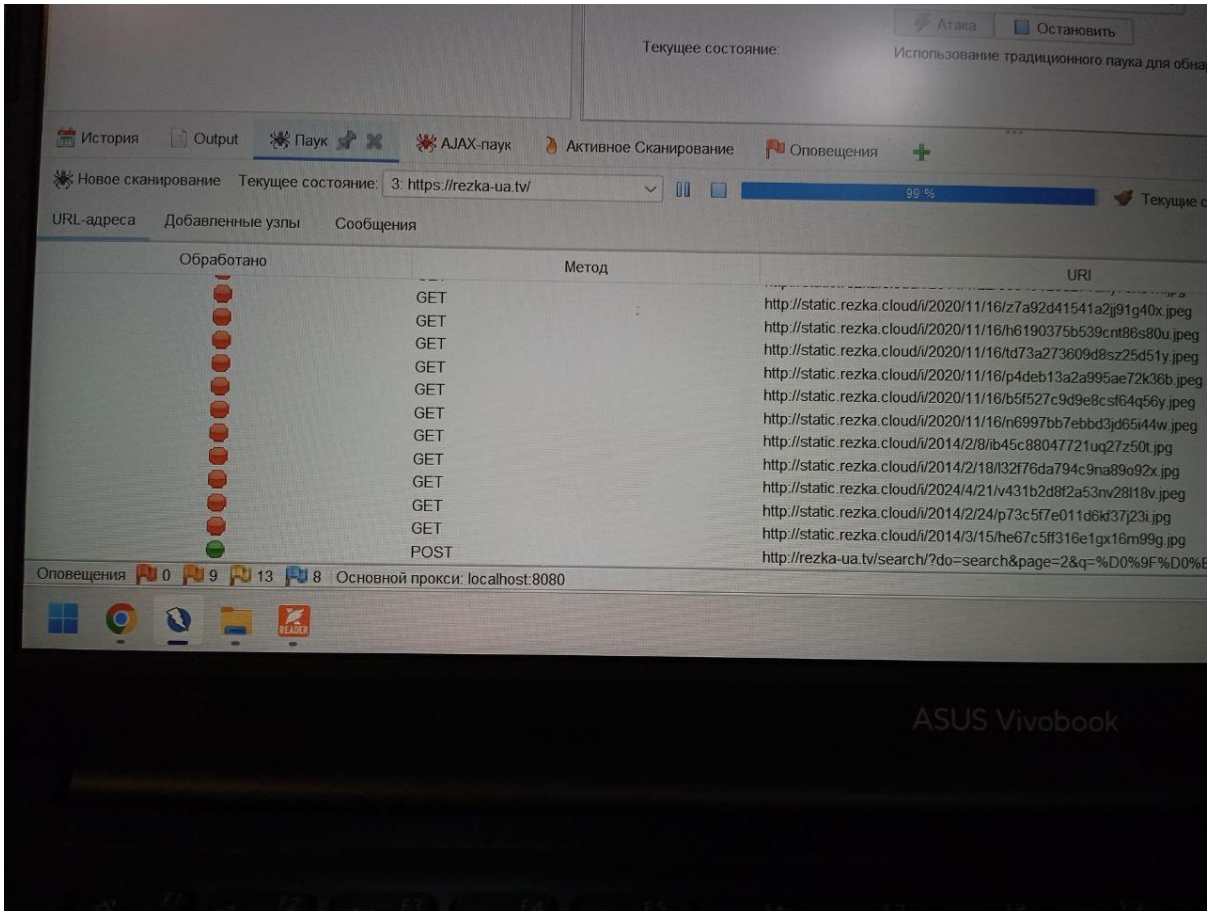

Текущее состояние:
Атака
Оповещения
Cookie без атрибута SameSite
URL-адрес: https://mylocal.md/
Риск: Low
Достоверность: Medium
Параметр: ci_session
Доказательства: Set-Cookie: ci_session
CWE ID: 1275
WASC ID: 13
Источник: Пассивный (10054 - Cookie без атрибута SameSite)
Alert Reference: 10054-1
Input Vector:
Описание:
A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. T
forgery, cross-site script inclusion, and timing attacks.
Дополнительно:

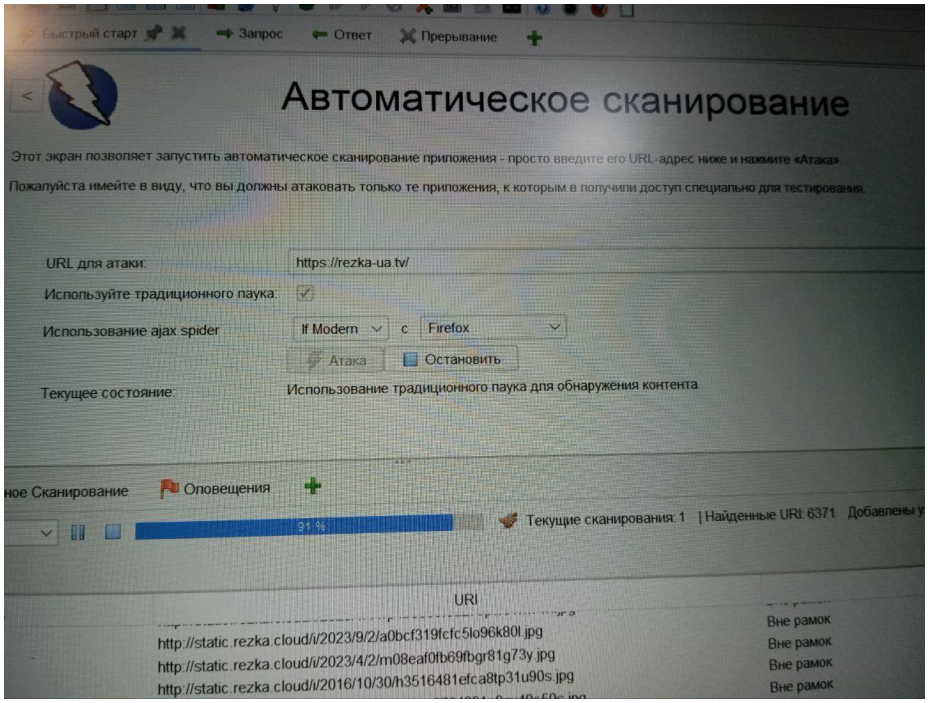


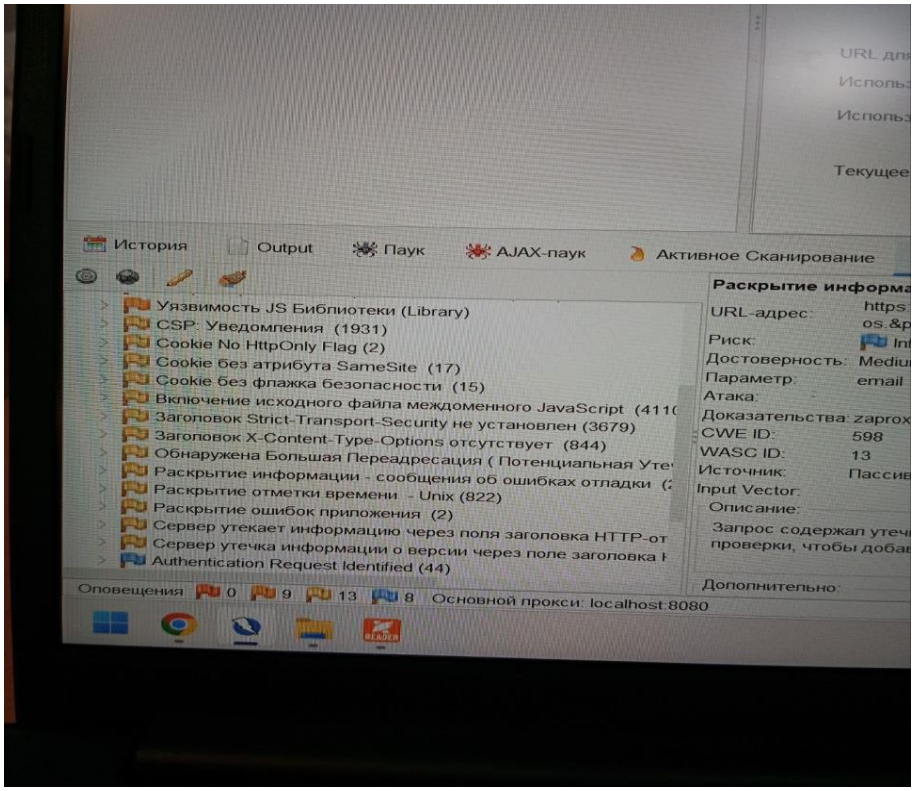

Импортировать Экспорт Онлайн Справка
Быстрый старт Запрос Ответ Прерывание
Заголовок: Текст Тело: Текст
HTTP/1.1 200 OK
Server: nginx/1.18.0 (Ubuntu)
Date: Thu, 20 Nov 2025 14:27:52 GMT
Content-Type: text/html; charset=UTF-8
Connection: keep-alive
Keep-Alive: timeout=5
Vary: Accept-Encoding
Set-Cookie: ci_session=qqn4f6672rogs75jfvb5315e9tjjm6l2; expires=Thu, 20-Nov-2025 16:27:52 GMT; Max-Age=
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
<!DOCTYPE html>
<html lang="ro" class="">
<head>
<meta charset="UTF-8" />
<meta name="viewport" content="width=device-width, initial-scale=1.0" />
<meta itemprop="name" content="mylocal.md" />
<meta itemprop="url" content="https://mylocal.md/" />
<meta name="description" content="Magazinul preturilor corecte" />
<meta name="keywords" content="" />
Оповещения
Cookie без флажка безопасности
URL-адрес: https://mylocal.md/
Риск: Low

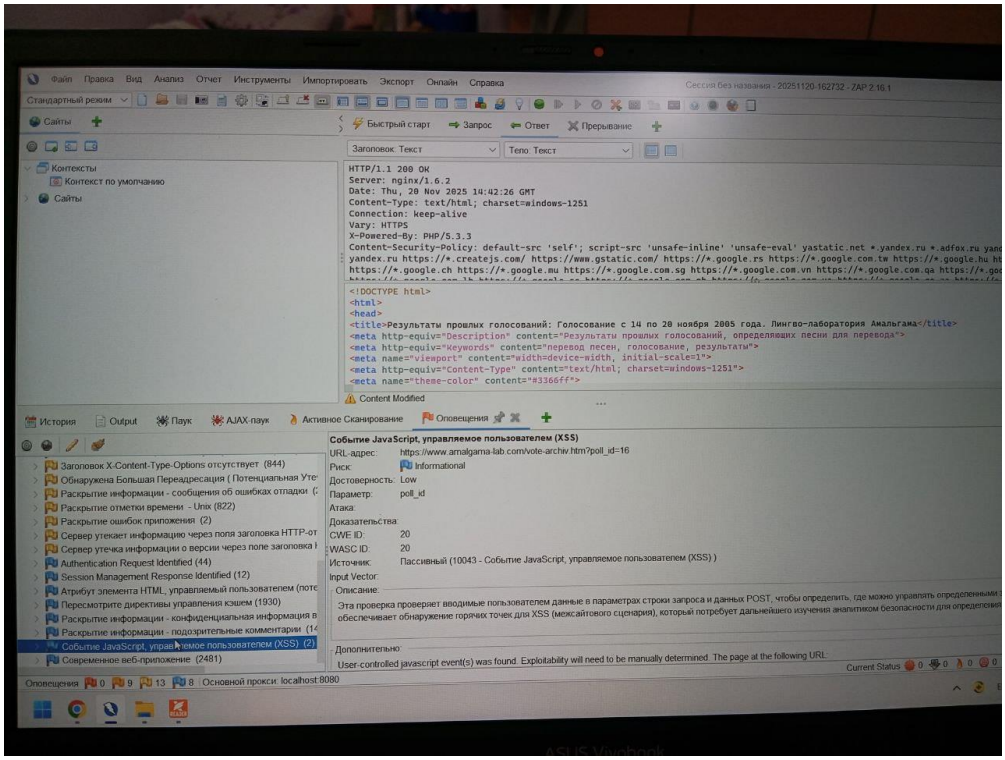
Rezka

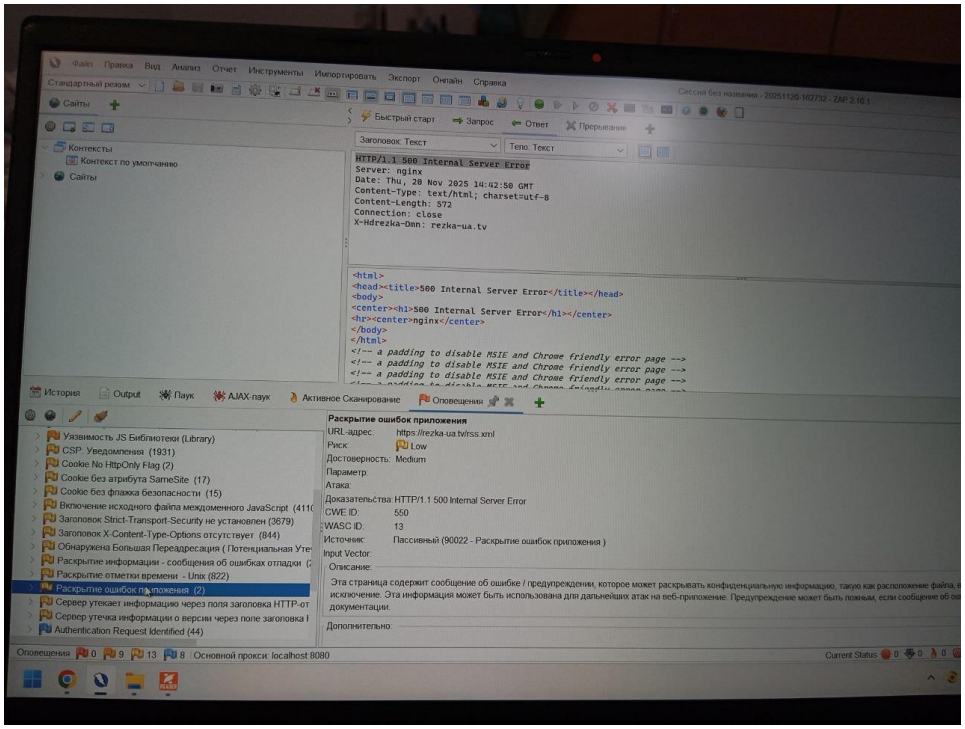

rezka-ua.tv
HD REZKA
Фильмы Сериалы Мультфильмы Аниме Новинки Анонсы Подборки
Поиск фильмов и сериалов
Новые фильмы, сериалы, мультфильмы и аниме
Убойная суббота
Битва за битвой
Икусагами: Последний самурай
Грабитель с крыши
Везунчики
Франкенштейн
Из многих
Во всём виновата она


Текущее состояние:
Атака
Остановить
Использование традиционного паука для обна
История
Output
Паук
AJAX-паук
Активное Сканирование
Оповещения
Новое сканирование
Текущее состояние: 3: https://rezka-ua.tv/
99 %
URL-адреса
Добавленные узлы
Сообщения
Обработано
Метод
URI
GET http://static.rezka.cloud/i/2020/11/16/z7a92d41541a2jj91g40x.jpeg
GET http://static.rezka.cloud/i/2020/11/16/h6190375b539cnt86s80u.jpeg
GET http://static.rezka.cloud/i/2020/11/16/td73a273609d8sz25d51y.jpeg
GET http://static.rezka.cloud/i/2020/11/16/p4deb13a2a995ae72k36b.jpeg
GET http://static.rezka.cloud/i/2020/11/16/b5f527c9d9e8csf64q56y.jpeg
GET http://static.rezka.cloud/i/2020/11/16/n6997bb7ebbd3jd65i44w.jpeg
GET http://static.rezka.cloud/i/2014/2/8/ib45c88047721uq27z50t.jpg
GET http://static.rezka.cloud/i/2014/2/18/l32f76da794c9na89o92x.jpg
GET http://static.rezka.cloud/i/2024/4/21/v431b2d8f2a53nv28l18v.jpeg
GET http://static.rezka.cloud/i/2014/2/24/p73c5f7e011d6kf37j23i.jpg
GET http://static.rezka.cloud/i/2014/3/15/he67c5ff316e1gx16m99g.jpg
POST http://rezka-ua.tv/search/?do=search&page=2&q=%D0%9F%D0%
Оповещения 0 9 13 8 Основной прокси: localhost:8080
ASUS Vivobook


Быстрый старт
Запрос
Ответ
Прерывание
Автоматическое сканирование
Этот экран позволяет запустить автоматическое сканирование приложения - просто введите его URL-адрес ниже и нажмите «Атака».
Пожалуйста имейте в виду, что вы должны атаковать только те приложения, к которым в получили доступ специально для тестирования.
URL для атаки: https://rezka-ua.tv/
Используйте традиционного паука:
Использование ajax spider: If Modern с Firefox
Атака
Остановить
Текущее состояние: Использование традиционного паука для обнаружения контента
ное Сканирование
Оповещения
91 %
Текущие сканирования: 1 | Найденные URI: 6371
URI
http://static.rezka.cloud/i/2023/9/2/a0bcf319fcfc5lo96k80l.jpg Вне рамок
http://static.rezka.cloud/i/2023/4/2/m08eaf0fb69fbgr81g73y.jpg Вне рамок
http://static.rezka.cloud/i/2016/10/30/h3516481efca8tp31u90s.jpg Вне рамок
Вне рамок


История
Output
Паук
AJAX-паук
Активное Сканирование
Уязвимость JS Библиотеки (Library)
CSP: Уведомления (1931)
Cookie No HttpOnly Flag (2)
Cookie без атрибута SameSite (17)
Cookie без флажка безопасности (15)
Включение исходного файла междоменного JavaScript (411
Заголовок Strict-Transport-Security не установлен (3679)
Заголовок X-Content-Type-Options отсутствует (844)
Обнаружена Большая Переадресация (Потенциальная Уте
Раскрытие информации - сообщения об ошибках отладки (
Раскрытие отметки времени - Unix (822)
Раскрытие ошибок приложения (2)
Сервер утекает информацию через поля заголовка HTTP-от
Сервер утечка информации о версии через поле заголовка
Authentication Request Identified (44)
Раскрытие информа
URL-адрес: https
os.&p
Риск: In
Достоверность: Mediu
Параметр: email
Атака:
Доказательства: zaprox
CWE ID: 598
WASC ID: 13
Источник: Пассив
Input Vector:
Описание:
Запрос содержал утеч
проверки, чтобы доба
Дополнительно:
Оповещения 0 9 13 8 Основной прокси: localhost:8080


Файл Правка Вид Анализ Отчет Инструменты Импортировать Экспорт Онлайн Справка
Стандартный режим
Сайты
Быстрый старт Запрос Ответ Прерывание
Заголовок: Текст
Тело: Текст
Контексты
Контекст по умолчанию
Сайты
HTTP/1.1 200 OK
Server: nginx/1.6.2
Date: Thu, 20 Nov 2025 14:42:26 GMT
Content-Type: text/html; charset=windows-1251
Connection: keep-alive
Vary: HTTPS
X-Powered-By: PHP/5.3.3
<!DOCTYPE html>
<html>
<head>
<title>Результаты прошлых голосований: Голосование с 14 по 20 ноября 2005 года. Лингво-лаборатория Амальгама</title>
<meta http-equiv="Description" content="Результаты прошлых голосований, определявших песни для перевода">
<meta http-equiv="Keywords" content="перевод песен, голосование, результаты">
<meta name="viewport" content="width=device-width, initial-scale=1">
<meta http-equiv="Content-Type" content="text/html; charset=windows-1251">
<meta name="theme-color" content="#3366ff">
Content Modified
История
Output
Паук
AJAX-паук
Активное Сканирование
Оповещения
Заголовок X-Content-Type-Options отсутствует (844)
Обнаружена Большая Переадресация (Потенциальная Уте
Раскрытие информации - сообщения об ошибках отладки (
Раскрытие отметки времени - Unix (822)
Раскрытие ошибок приложения (2)
Сервер утекает информацию через поля заголовка HTTP-от
Сервер утечка информации о версии через поле заголовка
Authentication Request Identified (44)
Session Management Response Identified (12)
Атрибут элемента HTML, управляемый пользователем (пото
Пересмотрите директивы управления кэшем (1930)
Раскрытие информации - конфиденциальная информация в
Раскрытие информации - подозрительные комментарии (1
Событие JavaScript, управляемое пользователем (XSS) (2)
Современное веб-приложение (2481)
Событие JavaScript, управляемое пользователем (XSS)
URL-адрес: https://www.amalgama-lab.com/vote-archiv.htm?poll_id=16
Риск: Informational
Достоверность: Low
Параметр: poll_id
Атака:
Доказательства:
CWE ID: 20
WASC ID: 20
Источник: Пассивный (10043 - Событие JavaScript, управляемое пользователем (XSS))
Input Vector:
Описание:
Эта проверка проверяет вводимые пользователем данные в параметрах строки запроса и данных POST, чтобы определить, где можно управлять определенными
обеспечивает обнаружение горячих точек для XSS (межсайтового сценария), который потребует дальнейшего изучения аналитиком безопасности для определения
Дополнительно:
User-controlled javascript event(s) was found. Exploitability will need to be manually determined. The page at the following URL:
Current Status
Оповещения 0 9 13 8 Основной прокси: localhost:8080



При сканировании сайта local с помощью OWASP ZAP я получила результаты **0, 8, 8 и 7 оповещений**. Это означает, что сайт имеет определённое количество уязвимостей, в основном связанных с настройками безопасности и отсутствием некоторых защитных заголовков. Уровень риска у магазина можно назвать умеренным.

Когда я проверила сайт **Telegram Web**, OWASP ZAP показал такие же значения — **0, 8, 8 и 7 оповещений**. Совпадение количества предупреждений говорит о том, что по уровню безопасности Telegram Web находится примерно на том же уровне, что и сайт магазина. Это может объясняться тем, что у них похожая структура ответов сервера или общие механизмы обработки запросов.

Сайт с фильмами дал совершенно иные результаты: **0, 9, 13 и 8 оповещений**. Здесь заметно больше предупреждений среднего и высокого уровня. Это показывает, что сайт значительно уязвимее. Вероятно, это связано с большим числом динамичных элементов, сторонних скриптов или недостаточно строгими настройками безопасности, что типично для подобных ресурсов.

Таким образом, сайт с фильмами оказался **наиболее уязвимым** из трёх. Telegram Web и сайт магазина демонстрируют примерно одинаковый уровень безопасности, тогда как сайт с фильмами требует большего внимания и исправления обнаруженных рисков.

Вывод

В ходе лабораторной работы я изучила назначение и возможности инструментов OWASP и на практике применила сканер безопасности **OWASP ZAP** для анализа трёх веб-приложений: local , Telegram и Rezka. Сканирование позволило определить количество оповещений и потенциальных уязвимостей, которые могут влиять на уровень безопасности веб-ресурсов.

Результаты показали, что сайт магазина и Telegram Web имеют одинаковый уровень обнаруженных предупреждений (**0, 8, 8, 7**), что свидетельствует о схожем наборе рисков, связанных в основном с настройками безопасности и защитными заголовками. Сайт с фильмами оказался более уязвимым (**0, 9, 13, 8**), что указывает на наличие дополнительных проблем — вероятно, связанных с динамическим контентом и внешними скриптами.

Использование OWASP ZAP помогло мне увидеть, какие типы рисков чаще всего встречаются в реальных веб-приложениях, и понять важность таких инструментов для защиты данных. Типичные уязвимости, которые выявляет OWASP ZAP, включают отсутствие защитных заголовков, недостаточную фильтрацию входных данных, риск XSS, проблемы конфигурации сервера и другие. Решить эти проблемы можно за счёт правильной настройки HTTP-заголовков (например, X-Content-Type-Options, X-Frame-Options), актуализации механизмов фильтрации, улучшения обработки запросов и регулярного тестирования безопасности.

Кроме OWASP ZAP существуют и другие инструменты для анализа уязвимостей веб-приложений, такие как **Burp Suite**, **Netsparker**, **Acunetix**, **Nikto**, **OpenVAS**. Они позволяют расширить возможности тестирования и обеспечивают более глубокий анализ безопасности.

Таким образом, лабораторная работа показала практическую ценность использования OWASP-инструментов и позволила мне научиться определять уязвимости, оценивать риски и понимать способы их устранения для повышения уровня безопасности веб-приложений.